Production API Security Test Execution Report

2026-10-26 IST | Low-impact production checks | No credentials or mutations

```
# Production API Security Test Execution ReportÐ
Ð
**Date:** 2026-10-26 (IST)  Ð
**Target:** `https://api.rcbmatka.com`  Ð
**Scope:** Non-disruptive, anonymous HTTP/TLS/authentication checks  Ð
**Result:** 9 checks completed; no service errors observed.Ð
Ð
## Safety boundariesÐ
Ð
- No production login or credential use.Ð
- No state-changing calls, account access with a valid token, payment actions,Ð
  file uploads, exploit payloads, fuzzing, enumeration, brute force, or loadÐ
  tests.Ð
- Requests were limited to nine low-rate GET/OPTIONS checks.Ð
- An invalid dummy bearer value was used only to verify that protected readÐ
  endpoints reject invalid authentication.Ð
Ð
## Execution summaryÐ
Ð
| Check | Result | Evidence |Ð
|---|---|---|Ð
| Protected endpoint, no authorization | **PASS** | `GET /api/getway-list`, `/api/user-chat-count`, and `/api/
get-profile-usser` each returned HTTP 401 with a JSON refusal. |Ð
| Protected endpoint, invalid bearer | **PASS** | `GET /api/getway-list` and `/api/user-chat-count` each
returned HTTP 401; no data was returned. |Ð
| Public settings data minimization | **PASS** | `GET /api/app-setting-list` returned only the documented `_id`
and 15 app fields; no sensitive player/staff fields were present. |Ð
| HTTP-to-HTTPS behavior | **PASS** | `GET http://api.rcbmatka.com/health` returned HTTP 301 to the HTTPS URL. |Ð
| CORS preflight | **OBSERVATION** | An unauthenticated `OPTIONS` preflight returned HTTP 200 with wildcard
origin, methods, and headers; credentials were not allowed. |Ð
| Security response headers | **HARDENING GAP** | HTTPS responses did not include HSTS, CSP, `X-Content-Type-
Options`, `X-Frame-Options`, or `Referrer-Policy`. `X-Powered-By` was absent. |Ð
| Service availability during checks | **PASS** | All nine checks completed without a network error; protected
routes returned expected auth refusals. |Ð
Ð
## FindingsÐ
Ð
| # | Severity | File | Lines | Vulnerability | Confidence |Ð
|---|----------|------|-------|---------------|------------|Ð
| 1 | ? LOW | `https://api.rcbmatka.com` | HTTPS response headers | Strict-Transport-Security was absent. Plain
HTTP currently redirects to HTTPS (301), but HSTS would instruct compatible clients to keep using HTTPS and
reduce downgrade exposure. | 8/10 |Ð
| 2 | ? LOW | `https://api.rcbmatka.com/api/getway-list` | OPTIONS response headers | CORS preflight allows
wildcard origins, methods, and headers. `Access-Control-Allow-Credentials` was absent and protected GETs
rejected missing/invalid bearer tokens, so no cross-origin data access was demonstrated. Review whether the
wildcard policy is intentional; restrict it if browser access is not meant to be public. | 8/10 |Ð
| 3 | ? LOW | `https://api.rcbmatka.com` | HTTPS response headers | Baseline browser hardening headers CSP, `X-
Content-Type-Options`, `X-Frame-Options`, and `Referrer-Policy` were absent on the sampled API/health responses.
These headers are defense-in-depth; applicability depends on whether responses are rendered as active browser
content. | 8/10 |Ð
Ð
These are low-severity configuration-hardening observations, not confirmedÐ
exploitable vulnerabilities. The checks did not establish that an attacker canÐ
read protected data, execute script, or downgrade a production session.Ð
Ð
## Endpoint-level evidenceÐ
Ð
| Method | Endpoint / target | Test data | HTTP | Result |Ð
|---|---|---|---:|---|Ð
| GET | `/api/getway-list` | No Authorization header | 401 | PASS ? JSON authentication refusal |Ð
| GET | `/api/getway-list` | Invalid dummy bearer token | 401 | PASS ? JSON invalid-session refusal |Ð
| GET | `/api/user-chat-count` | No Authorization header | 401 | PASS ? JSON authentication refusal |Ð
| GET | `/api/user-chat-count` | Invalid dummy bearer token | 401 | PASS ? JSON invalid-session refusal |Ð
| GET | `/api/get-profile-usser` | No Authorization header | 401 | PASS ? JSON authentication refusal |Ð
| GET | `/api/app-setting-list` | No credentials | 200 | PASS ? allowlisted public settings response |Ð
| GET | `/health` | HTTPS | 200 | PASS ? service reachable; hardening headers recorded above |Ð
| GET | `http://api.rcbmatka.com/health` | Plain HTTP | 301 | PASS ? redirects to HTTPS |Ð
| OPTIONS | `/api/getway-list` | Origin `https://security-check.invalid`; preflight for GET + Authorization |
200 | OBSERVATION ? wildcard CORS policy |Ð
Ð
## RecommendationsÐ
Ð
1. Consider enabling HSTS at the edge after confirming all intended subdomainsÐ
   are HTTPS-only. Avoid `includeSubDomains` or preload until the domain ownerÐ
```

   has verified every affected host.Đ
2. Review the wildcard CORS policy. If only known app/web origins need browserĐ
   access, return an explicit origin allowlist and narrowly scoped methods andĐ
   headers. Do not enable credentialed CORS with wildcard origins.Đ
3. Add appropriate browser security headers at the edge or application layerĐ
   where relevant. For API JSON, prioritize HSTS and `X-Content-Type-Options`;Đ
   CSP, framing, and referrer controls are most relevant if HTML is served.Đ
4. Repeat broader security testing in staging with written authorization. KeepĐ
   exploit reproduction, input fuzzing, rate-limit testing, and account-roleĐ
   tests out of production.Đ
Đ
LimitationsĐ
Đ
This is not a comprehensive penetration test. It did not test valid-tokenĐ
authorization scopes, expired signed tokens, blocked accounts, object-levelĐ
authorization across accounts, rate limiting, dependency vulnerabilities,Đ
payment callbacks, injection classes, or application/mobile behavior. ThoseĐ
tests require a dedicated staging environment and scoped authorization.Đ